The MESA MRM Framework

A Six-Step Model Risk Management Discipline for AI Systems

Nabeel Khan
iSystematic Inc.
ORCID 0009-0005-5364-914X

Framework Specification, Version 1.0
15 September 2026
doi.org/10.5281/zenodo.22285045
CC BY 4.0

Contents

Abstract **3**

Notation **4**
Defined terms . . . 4
Normative status of sections . . . 4

1. Introduction **4**
1.1 The problem . . . 4
1.2 What validation confers . . . 5
1.3 Contribution . . . 5
1.4 Scope . . . 5
1.5 Non-goals . . . 5

2. The Constitution (Normative) **6**
2.1 The permission, and what bounds it . . . 6
2.2 The two accountable loci . . . 6
2.3 The step order is normative and the step identifiers are frozen . . . 6
2.4 Entry conditions are evidence, not intent . . . 7
2.5 What every step record carries . . . 7

3. The Six Steps (Normative) **8**
3.1 What every step requires . . . 8
3.2 S1 Inventory . . . 9
3.3 S2 Pre-validation . . . 9
3.4 S3 Independent validation . . . 10
3.5 S4 Approval . . . 11
3.6 S5 Monitoring . . . 11
3.7 S6 Revalidation . . . 12
3.8 What the six steps do not do . . . 12

4. The Dual-Validation Branch (Normative, by Reference) **13**

5. The BOE Mapping (Normative) **13**
5.1 Every step record is a BOE Declaration . . . 13
5.2 Why the mapping matters . . . 13
5.3 The invariant this framework instantiates . . . 14

6. Composition, and One Edge This Specification Does Not Settle (Normative) 14
6.1 What this framework consumes . . . 14
6.2 What this framework supplies . . . 14
6.3 One edge this specification records and does not settle . . . 15

7. Conformance (Normative) 16
7.1 Self-declared, and nothing else . . . 16
7.2 What a conformance claim requires . . . 16
7.3 What MUST accompany a claim . . . 16
7.4 What a conformance claim does not mean . . . 16
7.5 Lapse . . . 16

8. Related Work 16
8.1 Supervisory model risk guidance . . . 16
8.2 Management system standards . . . 17
8.3 The governance family . . . 17
8.4 The source treatment . . . 17

9. Limitations and What Has Not Been Tested 17
9.1 No institution unconnected to the author has been observed operating the six steps . . . 17
9.2 The central claim is untested and the comparison is not obvious . . . 17
9.3 It is calibrated to institutions that can staff it . . . 17
9.4 The regulatory crosswalk is informative, and it dates . . . 17
9.5 Retirement is named and not specified . . . 18
9.6 The tiering rubric is required and is not supplied . . . 18
9.7 The name has not been cleared . . . 18
9.8 What would falsify the framework . . . 18
9.9 Research questions . . . 18

10. Versioning 18

11. References 19

Annex A (Informative). The Regulatory Crosswalk 20
A.1 What this annex is, and what it is not . . . 20
A.2 The two instruments as verified . . . 20
A.3 The six steps against Guideline E-23 . . . 21
A.4 The six steps against SR 26-2 . . . 22
A.5 Four places where this framework is stricter than both instruments . . . 22
A.6 Three places where an instrument reaches further than this framework . . . 23
A.7 The scope divergence that matters most . . . 23
A.8 What the institution must do . . . 23
A.9 Verification record . . . 24

Annex B (Normative). The Validation Report Template 24

Annex C (Informative). A Worked Example 25

Appendix D (Informative). Naming Crosswalk to the Source Treatment 26
D.1 Structures that are prior treatment and are not this specification's structure . . . 26
D.2 One assignment in the source treatment that this specification and its siblings forbid . . . 27
D.3 Terms that carry forward unchanged . . . 27

Appendix E (Informative). Figure Specifications 27

Appendix F. Publication Provenance 28

Document History 28

About the Author 28

doi.org/10.5281/zenodo.22285045

Licence **29**

How to attribute this work **29**

Framework Specification, Version 1.0

Author: Nabeel Khan
ORCID: 0009-0005-5364-914X
Affiliation: iSystematic Inc.
Version: 1.0
Date: 15 September 2026
Status: Public technical specification. Self-declared conformance only. Not a certification scheme.
Licence: Creative Commons Attribution 4.0 International (CC BY 4.0)
DOI (cite this): https://doi.org/10.5281/zenodo.22285045
This version: https://doi.org/10.5281/zenodo.22285046

Cite as: Khan, N. A. (2026). *The MESA MRM Framework: A Six-Step Model Risk Management Discipline for AI Systems. Framework Specification, Version 1.0.* Zenodo. https://doi.org/10.5281/zenodo.22285045

Trademark notice. The MESA MRM Framework™, the MESA Framework™ and CADRE™ are trademarks of the author and iSystematic Inc. Text licensed CC BY 4.0; the licence grants no rights in the marks. The Boundary Invariant and the BOE Declaration, referenced throughout, are deliberately unmarked and belong to the engineering family specified at [2].

Annex A is informative. It carries a crosswalk to two supervisory instruments. A crosswalk dates. Annex A states the date of its verification, and an institution relying on it MUST re-verify against the primary sources in force where it operates. The crosswalk is the institution's obligation to perform and to maintain. It is not this framework's obligation to guarantee, and nothing in Annex A establishes compliance with either instrument.

Abstract

An institution that runs models can usually say which of them work. It is much less often able to say who decided that they work, on what evidence, for what use, and until when. The second set of facts is the one a supervisor, a board or an incident review asks for. Model risk machinery built for analytic rigour tends not to produce it, because it was built to reach a verdict rather than to record a permission.

This specification defines the **MESA MRM Framework™**, a six-step model risk management discipline for AI systems. The steps are **inventory**, **pre-validation**, **independent validation**, **approval**, **monitoring** and **revalidation**, in that order. Each step carries entry conditions naming the framework that supplies them, one accountable role, a defined return path, and one evidence artifact.

The framework rests on a single principle, and the principle is the reason the six steps are ordered as they are. **A validation is not a property of the model. It is a bounded permission, held by the institution, over a stated use, for a stated period.** A validated model has not acquired an attribute it carries into any future use. It has been granted a permission whose boundaries were written down, and everything after step three tests whether those boundaries still hold.

Two accountable loci are named, and the separation between them is the framework's structural claim. **The head of model risk is accountable for the discipline. A named approving executive is accountable for each individual approval. The two MUST NOT be held by one person for the same model**, because the independence of the validation is the property the framework exists to establish, and an institution in which the person running validation also accepts its output has a review function rather than a second line.

Every step record is stated as an instance of the BOE Declaration [2]. That is what allows a validation record to be joined with a gate record, a residency attestation and a vendor screening record during an incident reconstruction rather than merely filed beside them.

The specification states what would falsify the framework, ships the validation report template and the worked example its registry entry records as missing, and carries an informative regulatory crosswalk at Annex A. **No institution unconnected to the author has been observed operating the six steps.** Section 9 states that first, and states what else has not been tested.

It is a specification, not a certification scheme, and no conformity assessment body operates against it.

Keywords: model risk management; AI governance; independent validation; model inventory; revalidation; accountability; evidence architecture; supervisory guidance; regulated industries.

Notation

This specification uses **MUST**, **MUST NOT**, **SHOULD**, **SHOULD NOT** and **MAY** as the normative verbal forms.

- **MUST** indicates a requirement. An implementation that does not meet it is not conformant with this specification.
- **SHOULD** indicates a recommendation. Departure requires a recorded rationale.
- **MAY** indicates a permission.

The MESA Framework specification [1] and A Pattern Language for Production LLM Platforms [2] use the verbal forms of ISO/IEC Directives Part 2, in which **shall** carries the meaning assigned to MUST here. The correspondence is exact.

Defined terms

Model. A method, system or approach whose output is used to inform an institutional decision and whose behaviour is determined by learned parameters, fitted relationships or stated theory rather than by an enumerated rule the institution wrote out in full. An AI or machine learning system is a model for the purposes of this framework whether or not it is a model for the purposes of any supervisory instrument, and Annex A records where those two answers differ.

AI system. A model, an agent, or a service whose behaviour is materially determined by a model, together with the configuration and policy that bound it. The unit registered at step one is the AI system, not the model alone, because a model with different guardrails is a different system.

First line. The function that builds, configures or operates the model and owns the outcome it produces. **Second line.** The function that examines the first line's work and does not own that outcome.

Bounded permission. The output of step four: a statement that a named person accepts a stated use of a stated system, on stated evidence, subject to stated conditions, and until a stated date or a stated trigger.

Evidence artifact. A record written so that a decision can be reconstructed by a party who was not present when it was taken, as distinguished from a log written for debugging.

Institution. The accountable legal entity operating the models this framework governs. **Regulated institution** means one whose ability to operate is conditioned on its ability to defend a decision to an external authority.

Normative status of sections

Sections 2 through 7 are normative. Sections 1, 8, 9 and 10 are informative, except where they state a requirement using **MUST**. **Annex A is informative in its entirety.** Annex B is normative. Annex C is informative. The appendices are informative.

---

1. Introduction

1.1 The problem

Model risk management is one of the oldest governed disciplines in financial services, and most institutions that operate AI systems already have a version of it. The version usually works. Models are documented, validators are technically strong, findings are raised, and reports are filed.

The discipline nonetheless fails at a predictable point, and it fails the same way in institutions that are otherwise unalike. It produces a verdict and does not produce a permission. A validation concludes that the model is fit, the conclusion is recorded, and nothing then holds the edges of it. The use widens. The population drifts away

doi.org/10.5281/zenodo.22285045

from the one the model was validated on. The person who accepted it moves roles. A year passes. No artifact expires, because none was given an expiry, and the institution's belief about the model becomes older than the model without anyone deciding that it should.

Model risk functions do not fail because their validators lack technique. They fail because the permission the validation produced was never bounded, so nothing in the institution could tell when it had lapsed.

The second failure is quieter and is structural. In many institutions the person who runs the validation function is also the person who accepts its conclusions into production, formally or in the way the meeting actually works. Every incentive in that arrangement points one way: the function that would have to report its own validation as insufficient is the function whose approval would then be in question.

1.2 What validation confers

A validation is not a property of the model. It is a bounded permission, held by the institution, over a stated use, for a stated period.

The distinction changes what the artifacts have to contain. A property travels with the object. If validation were a property, a validated model could be moved to a new use, a new population or a new jurisdiction and remain validated. That is the reasoning behind the most common category of model incident. A permission does not travel. It names what was permitted, and a use outside that naming is unpermitted whether or not anyone noticed.

The registry entry for this framework states the same principle in its shorter form: validation confers the right to be believed [3, 4.2.5]. This specification states it in its operative form, because the operative form is what an artifact can be tested against. **Where the two statements are read together, this specification governs the framework and the registry governs the framework's place in the architecture** [3, 11.3].

1.3 Contribution

1. **Six steps in a normative order**, each naming the framework that supplies its entry conditions, one accountable role, a return path and one evidence artifact. Section 3.
2. **Two accountable loci with a separation stated as a MUST**, and the reasoning for the separation given once rather than at every step. Section 2.2.
3. **A mapping from every step record to the BOE Declaration** [2], which is what makes a validation record joinable with the records of frameworks specified elsewhere. Section 5.
4. **A validation report template and a worked example**, at Annex B and Annex C, closing the missing artifact the registry entry records at [3, 4.2.13].
5. **An informative regulatory crosswalk**, at Annex A, closing the asserted limitation the registry entry records at the same place, in the only honest form available to a document that is not a supervisor.

1.4 Scope

The framework governs the institutional discipline by which a model becomes permitted, stays permitted, and stops being permitted. It is calibrated to regulated institutions, and 9.3 states what changes for an institution that is not one.

1.5 Non-goals

- **Not a validation methodology.** The framework specifies the discipline, not the statistical or behavioural methods a validator applies within it. A strong discipline over weak technique produces well-recorded errors.
- **Not a deployment model.** The passage of a system into production is governed by the Five-Gate Deployment Model [4], which consumes this framework's outputs. Section 6 states the composition.
- **Not a specification of the frameworks supplying its inputs.** What a classification must cover, what to ask a vendor [6], and what constitutes an incident belong to the frameworks catalogued at [3].
- **Not a certification scheme.** No conformity assessment body operates against this specification.
- **Not a statement of regulatory compliance.** Operating the six steps does not establish compliance with any statute or supervisory expectation. Annex A is a crosswalk, not a compliance claim.
- **Not an empirical claim.** Section 9 states what has not been tested.

doi.org/10.5281/zenodo.22285045

2. The Constitution (Normative)

2.1 The permission, and what bounds it

Step four produces a bounded permission and MUST NOT produce anything less. A permission is bounded when the record states all five of the following, and a record missing any of them is not an approval record for the purposes of this specification.

#	Bound	Why it is required
1	**The system and its version**	A different configuration is a different system, and one permission does not extend to another
2	**The permitted use**	Including the decisions the output may inform and the decisions it may not
3	**The permitted population**	Performance on an unexamined population is unknown rather than acceptable
4	**An expiry or a revalidation trigger**	An approval that never expires is an approval nobody will revisit
5	**The open conditions, dated and owned by a named person**	An unrecorded condition is one nobody will close

A permission is not renewed by the absence of bad news. It is renewed at step six, by a decision, on evidence.

2.2 The two accountable loci

This framework operates at two accountable loci, and each MUST be occupiable by one person.

- **The head of model risk**, in the second line, is accountable for the discipline: that the inventory is complete, that tiers are assigned by a documented rubric, that validations are performed at the depth the tier requires, that monitoring is designed adequately, and that revalidation triggers are defined in advance.
- **The named approving executive** is accountable for each individual approval: that the permission granted was granted on the evidence, and that its bounds were stated.

These two roles MUST NOT be held by one person for the same model. A committee, a function, a team or a board MUST NOT be recorded in either role, and an approval record naming a committee does not satisfy this section or [3, 3.3].

The reason is the one property the framework exists to establish. An independent validation is worth what its independence is worth. Where the person accountable for the quality of the validation also accepts its output, a finding that the validation was insufficient is a finding against the approver, and the cheapest response to a weak validation becomes approving on it. The separation costs two appointments and buys the only condition under which the validation's conclusion is information rather than a formality.

Two consequences follow and each is normative.

1. **Both roles MUST be named in advance**, in the decision-rights assignment of the institution's governance function [3], and MUST NOT be selected at the moment a model is ready to be approved.
2. **A named deputy MUST be part of each appointment**, for the reason 2.3 of [4] gives. A model ready for approval does not wait.

Two loci are two accountable persons, and neither is a shared one [3, 3.3]. What remains forbidden is a role no single person can occupy.

2.3 The step order is normative and the step identifiers are frozen

A model MUST pass steps one through six in that order, and MUST NOT enter a step whose predecessor it has not completed. The order is not a convention. Each step consumes something the previous one established. Reordering produces a decision taken on evidence that did not yet exist. An approval before a validation is an approval of an assumption, and a validation before an inventory entry is a validation of a system nobody has assigned an owner or a tier.

doi.org/10.5281/zenodo.22285045

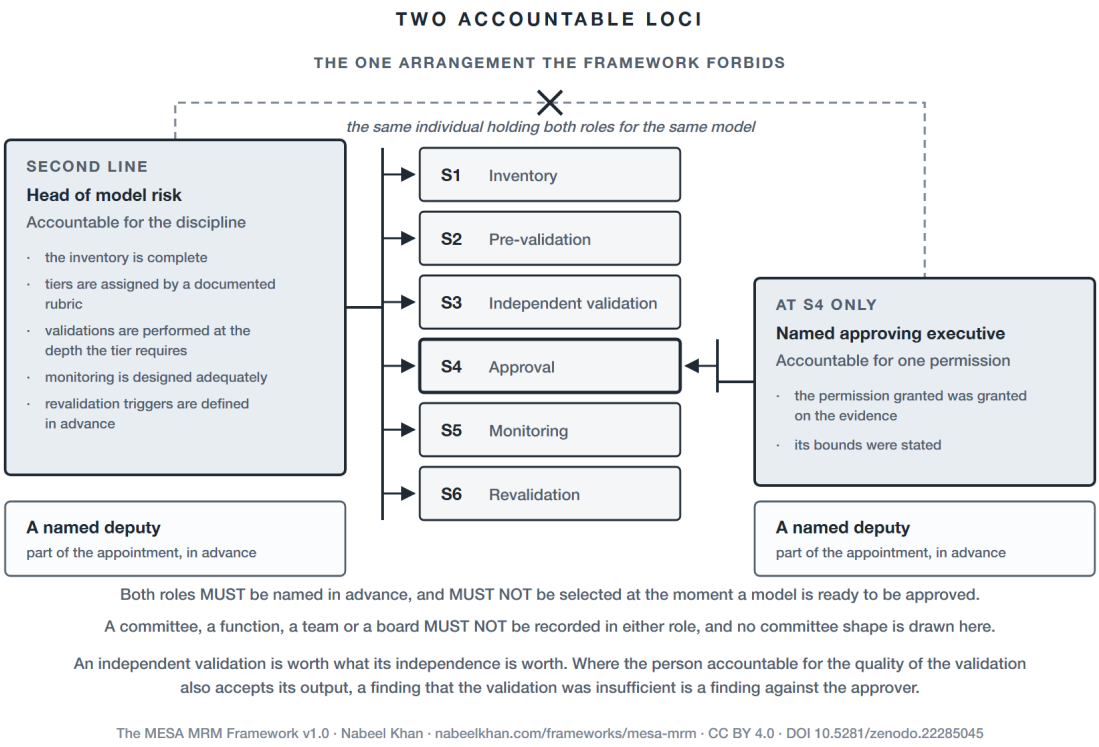


Figure 1. The two accountable loci and the separation between them. The head of model risk owns the discipline across all six steps and is accountable for the inventory, the tiering rubric, validation depth, monitoring design and the trigger register. The named approving executive owns one permission at step four and is accountable for its bounds and for the evidence it was granted on. The dashed prohibition between them marks the one arrangement the framework forbids: the same individual holding both roles for the same model. DOI https://doi.org/10.6084/m9.figshare.33420160

The six steps carry the stable identifiers S1 to S6, which correspond exactly to the ordinals used in the registry entry and in the specifications that thread into this one. S3 is the step the dual-validation branch enters [3, 5.2 row 28]. S6 is the step revalidation triggers reopen [3, 4.2.8].

The identifiers and the ordinals MUST NOT be renumbered. They are fixed by the registry's relationship register, which addresses this framework's steps by ordinal in published, immutable records, and a renumbering would silently invalidate every citation resolving through them. A step retired in a future version retains its identifier, which is marked retired rather than reused. Where the identifier form and the ordinal form could ever differ, **the ordinal governs**, because the ordinal is the form the registry uses.

2.4 Entry conditions are evidence, not intent

Every entry condition in Section 3 MUST name an artifact that either exists or does not. Policy, training, intent and scheduled work MUST NOT be recorded as satisfying an entry condition.

This rule is inherited rather than invented. It is the same rule the MESA Framework applies through its enforcement constraint, under which a control the technical substrate cannot enforce operates at the maturity of the substrate rather than at the maturity of the policy [1], and the same rule the registry applies at [3, 3.4].

Where an entry condition cannot be met and the institution nonetheless intends to proceed, the step MUST be recorded as **completed with conditions**, each condition dated and owned by a named person, and the accountable person at the next step MUST be shown the open conditions before deciding. **An unrecorded exception is a skipped step.**

2.5 What every step record carries

Every step in Section 3 produces exactly one evidence artifact, and every such artifact MUST carry, at minimum:

- the AI system and the version of it the step examined;
- the step;

doi.org/10.5281/zenodo.22285045

- the outcome, and any conditions attached to it;
- the name of the accountable person, and the role they held;
- the evidence relied on, identified so that it can be retrieved;
- the tier in force, and the version of the rubric that assigned it;
- the policy version in force at the time;
- the date.

The policy version is the field this record is most often missing, and 2.5 of [4] states why a reconstruction needs it. A tiering decision defensible in March can be indefensible in September under a rubric nobody touched. The policy moved.

---

3. The Six Steps (Normative)

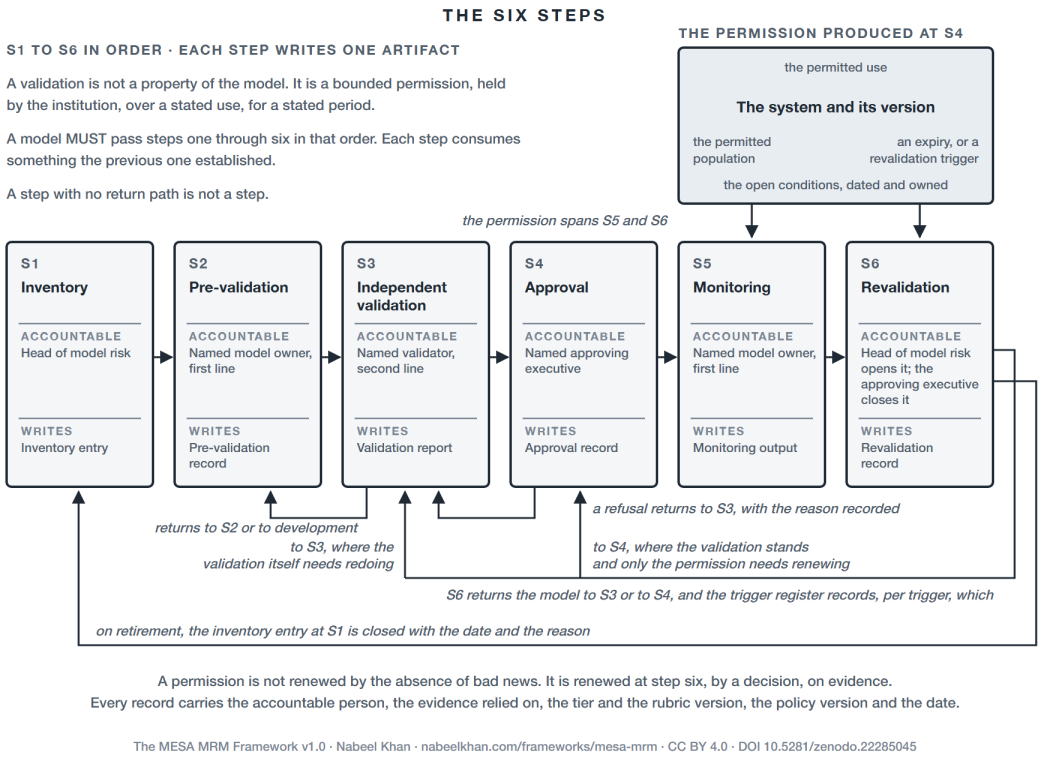


Figure 2. The six steps in order, the permission each contributes to, and the artifact each writes. S1 registers the system and assigns its tier; S2 states what the builder claims; S3 tests those claims independently; S4 converts the tested claims into a bounded permission held by a named person; S5 tests continuously whether the conditions of that permission still hold; S6 reopens the permission on a trigger. Return paths run from S3 to S2, from S4 to S3, and from S6 to S3 or S4 according to whether the validation or only the permission needs renewing. DOI https://doi.org/10.6084/m9.figshare.33420169

3.1 What every step requires

Every step below carries the same six elements, stated once here rather than six times.

#	Element	What it fixes
1	**Entry conditions**	What MUST exist before the step may begin, and which framework produces it
2	**Accountable role**	The named person who answers for the step, and which of the two loci at 2.2 answers for its adequacy
3	**Outcome vocabulary**	The closed set of results the step may produce

doi.org/10.5281/zenodo.22285045

#	Element	What it fixes
4	**Output artifact**	The one evidence record the step writes, per 2.5
5	**Return path**	Where a system goes when the step does not complete, and what MUST change before it returns
6	**Tier sensitivity**	What the risk tier changes about the step, and what it does not

A step with no return path is not a step. A stage that can only be completed is a formality, and the institution learns nothing from it.

3.2 S1 Inventory

Purpose. To make the population of models a known set, so that every claim made after it has a denominator.

Entry conditions.

Condition	Supplied by
A documented tiering rubric, versioned, in force before the model's result is known	The institution
A named owner, who is one person	The institution
The intended use, and the decisions the system will inform	The institution

Accountable role. The head of model risk, for the completeness of the inventory and for the rubric. The named owner is recorded in the entry and carries the model.

Outcome vocabulary. Registered, or registered as out of scope with the reason stated.

Output artifact. An inventory entry carrying the system, its version, its owner, its tier, the rubric version that assigned the tier, and the date.

Return path. S1 is the entry point and has no predecessor. **A model discovered in production and absent from the inventory MUST be registered, MUST re-enter at S2, and its unregistered operation MUST be recorded as an exception with a named owner and a date.** Registering it silently as though it had always been there destroys the only record that the control failed.

Tier sensitivity. The tier is assigned here and determines the depth of S2 through S6. **The rubric MUST be applied before the model's performance is known.** A tier assigned after a result is a tier assigned by the result, and the model that most needs the deeper treatment is the one whose result made the deeper treatment look unnecessary.

A model absent from the inventory is not a model the institution governs, whatever its documentation, and MUST NOT proceed to S2. Inventory determines coverage. Coverage determines what monitoring can see. What monitoring can see determines what revalidation can be triggered by.

3.3 S2 Pre-validation

Purpose. To establish, by the first line, that the model is examinable, and to fix in writing the claims that S3 will test.

Entry conditions.

Condition	Supplied by
The inventory entry, with owner and tier	S1
Data classification and lineage reaching from an attested source to the point of use	AI Data Governance [3]
Vendor evidence, where any component of the model is third-party	AVRF [3][6]
A stated assumption register and a stated set of limits, written by the builder	The first line

doi.org/10.5281/zenodo.22285045

Accountable role. The named model owner, in the first line.

Outcome vocabulary. Complete, complete with conditions, or not complete.

Output artifact. A pre-validation record carrying the lineage reference, the classification relied on, the assumption register, the stated limits, the intended use, and the vendor evidence identifier where applicable.

Return path. A model whose pre-validation does not complete returns to development. The record MUST name which condition failed.

Tier sensitivity. The tier sets the depth of the assumption register and the granularity of the lineage required. It does not make any of the four entry conditions optional.

The stated limits are the object of the validation, which is why the builder states them first. A limit the validator discovers that the builder did not state is a finding about the pre-validation as much as about the model, and MUST be recorded as one. An institution whose builders state no limits has moved the burden of imagining failure onto the party with less knowledge of the system.

Where the model is third-party, the institution states what it can and cannot examine. Vendor evidence enters here and again at S3, and what to ask a vendor is specified by the AVRF instrument [6] and is not restated in this document.

3.4 S3 Independent validation

Purpose. To test the claims fixed at S2, by a party with no stake in the model passing.

Entry conditions.

Condition	Supplied by
The pre-validation record, complete or complete with recorded conditions	S2
A named validator meeting the independence requirements below	The second line
A validation scope set by the tier and recorded before the work begins	The head of model risk
Where a Sharia Supervisory Board holds binding approval power, the Sharia validation track opened	SACF [3][5]

Independence. The validator **MUST NOT** be a member of the team that built or configured the system; **MUST NOT** report, for this work, through the owner of the business outcome the model serves; and **MUST NOT** be the approving executive at S4 for the same model. The third requirement is the same separation the Five-Gate Deployment Model states at its second and third gates [4, 2.3], expressed here at the discipline rather than at the gate.

Accountable role. The named validator, under the head of model risk.

Outcome vocabulary. Closed, **closed with conditions**, or **not closed**. A validation that is closed with conditions states each condition, its owner and its date. A finding that the model is fit for a narrower use than proposed is a closure with conditions, and **the narrowing MUST be carried into the permitted use at S4 rather than noted in prose**.

Output artifact. A validation report conforming to Annex B. **A validation report that no second-line reviewer signed is not evidence of independent validation** [3, 4.2.11].

Return path. A model whose validation does not close returns to S2 or to development, and the record MUST state which and why.

Tier sensitivity. The tier sets the depth of testing and the seniority of the validator. **It does not make independence optional at any tier.** An institution that validates low-tier models inside the building team has removed the control and kept the name.

What the report MUST state that reports usually omit. The limitations, failure modes and populations the validation **did not examine**. An approval is blind in exactly the shape of that set, and the approver cannot see the shape unless the report draws it. Annex B makes it a required section for this reason.

doi.org/10.5281/zenodo.22285045

3.5 S4 Approval

Purpose. To convert a closed validation into a bounded permission held by a named person who will answer for it.

Entry conditions.

Condition	Supplied by
The validation report, closed or closed with recorded conditions	S3
The approval package: intended use, validated limits, residual risk, open conditions, the unexamined set	S3
The approval authority itself, assigned in advance to a named person	CADRE™ [3]
Where SACF applies, both validation tracks closed, civil and Sharia	SACF [3][5]

Accountable role. The named approving executive. **This is the locus at which the framework's central property is exercised**, and 2.2 applies to it without exception.

Outcome vocabulary. Approved, approved with conditions, or refused.

Output artifact. An approval record naming the person, the evidence relied on, the five bounds of 2.1, and the date. **An approval record naming a committee rather than a person does not satisfy 2.2 or [3, 3.3] and is not an approval record.**

Return path. A refused model returns to S3 with the reason recorded. **An approver who refuses for a matter the validation did not examine MUST record that as a finding against validation scope**, so that the next validation examines it. This mirrors the rejection path the Five-Gate Deployment Model states at its third gate [4, 3.4], and the mirroring is deliberate: a refusal that teaches the validation nothing will be met by the same validation again.

Tier sensitivity. The tier sets the seniority of the approver and the maximum period a permission may run before S6 reopens it. It does not change what the approval record must contain.

Signing on the evidence rather than on the recommendation. An approver who accepts a recommendation without identifying the evidence has added a signature and no scrutiny. The approval record MUST identify the evidence relied on, and **where the approver departs from the validator's recommendation in either direction, the record MUST state the departure and its reason.** A defensible departure is defensible in writing, and one that is not is the most valuable line an incident reconstruction will find.

3.6 S5 Monitoring

Purpose. To test continuously whether the conditions the permission was granted under still hold.

Entry conditions.

Condition	Supplied by
The approval record, with its conditions and bounds	S4
Monitoring live, covering every condition the approval was conditioned on	The platform
The populations the validation examined, recorded so that production can be compared against them	S3

Accountable role. The named model owner operates the monitoring. The head of model risk remains accountable for whether its design is adequate to the tier, which is part of the discipline rather than a third locus.

Outcome vocabulary. Within conditions, within conditions with findings, or out of conditions.

Output artifact. Monitoring output covering the period since approval, **with gaps named rather than interpolated**. A monitoring record that is silent about a period of no data is asserting coverage it does not have.

Return path. A model that cannot be monitored against its approval conditions MUST NOT operate. **A model in production without live monitoring is not at S5. It is at S4 with an unmet condition**, and it is returned

doi.org/10.5281/zenodo.22285045

rather than left running while monitoring is arranged. The Five-Gate Deployment Model states the same refusal at its fifth gate [4, 3.6].

Tier sensitivity. The tier sets the frequency and the alerting thresholds. It does not make any monitored condition optional where the approval named it.

What MUST be monitored. At minimum: every condition the approval record named; drift in the input distribution and in the output distribution; the population served against the population validated; and **the override rate**, meaning the rate at which the humans who receive the model's output overturn it.

Monitoring is not observation. It is the test of the conditions the permission was granted under. The override rate earns its place because it is the cheapest available signal that the model and the people relying on it disagree, and the one institutions most often collect and never read. An override rate nobody measures is a disagreement the institution has chosen not to hear.

3.7 S6 Revalidation

Purpose. To reopen the permission on a trigger rather than on the calendar alone, and to decide again.

Entry conditions.

Condition	Supplied by
The revalidation trigger register, populated before the model served production traffic	The head of model risk, before S5 began
Monitoring output for the period	S5
Incident findings and revalidation triggers raised by incident response	AIRP [3]
The approval record whose bounds are being reopened	S4

Accountable role. The head of model risk, for the register and for opening the revalidation. The approving executive, or the successor in that role, for the decision that closes it.

Outcome vocabulary. Continued, narrowed, suspended, or referred for retirement.

Output artifact. A revalidation record stating the trigger that fired, what was re-examined, what was not, and the decision with its new bounds.

Return path. A revalidation returns the model to **S3** where the validation itself needs redoing, and to **S4** where the validation stands and only the permission needs renewing. **The trigger register MUST record, for each trigger, which of the two it causes.** A register that does not distinguish them turns every trigger into either a full revalidation nobody has capacity for or a rubber stamp.

Tier sensitivity. The tier sets the maximum interval after which a revalidation occurs even when no trigger has fired, so that a model nothing has happened to is still revisited.

The register MUST be populated in advance, and **which incidents reopen validation MUST NOT be decided after an incident by the people whose work would be reopened** [4, 4.2]. This is the requirement with the most direct incentive against it, and it is stated for that reason.

Triggers MUST include, at minimum: a monitored condition breaching its threshold; drift beyond the stated tolerance; a change to the model, its training data, its configuration or its guardrails; a change to the population it serves; a change to the policy in force; an incident raised under AIRP; and the expiry of the permission.

Retirement. A model referred for retirement leaves this framework by a recorded decision under the Five-Gate Deployment Model [4, 4.3], and **its inventory entry at S1 MUST be closed with the date and the reason.** The framework produces the finding. It does not perform the retirement, and 9.5 records that as a scope limitation.

3.8 What the six steps do not do

The steps do not make a model correct. They make the institution's belief about the model dated, bounded, attributable and re-openable. An institution operating the six steps over validations that examine nothing has a well-recorded formality, which is why S3 requires a scope set in advance and Annex B requires the unexamined set to be drawn.

doi.org/10.5281/zenodo.22285045

4. The Dual-Validation Branch (Normative, by Reference)

Where a Sharia Supervisory Board holds binding approval power over the institution, **S3 carries a dual-validation branch, and both tracks MUST close before S4 may begin.**

The branch is specified at Section 4 of the Sharia AI Compliance Framework [5], and this specification does not restate it. What the Sharia track examines, how the two tracks are kept independent of each other, and what the dual-validation record must show are that specification's subject, and a second statement of them here would be a second statement that could drift from the first. The registry forbids the duplication for the same reason [3, 5.4].

Three obligations fall on this framework rather than on that one, and they are stated here because they are properties of the six steps.

1. **The branch point is S3 and is not movable.** The registry asserts the thread into step three [3, 5.2 row 28]. A branch inserted at S4 would be an approval reviewing a closure rather than a closure conditioning an approval.
2. **S4 MUST NOT begin until both closures exist**, and the approval record MUST identify both by identifier. **A closure in one track MUST NOT be recorded as partial satisfaction of the other** [5, 4.1].
3. **Where the branch applies, the two honesty clauses that accompany SACF everywhere accompany any presentation of this branch**, per [3, 8.2] and the front matter of [5]. In summary and without substituting for their published wording: no Sharia Supervisory Board has reviewed or endorsed that specification, and it makes no Sharia determination.

---

5. The BOE Mapping (Normative)

5.1 Every step record is a BOE Declaration

A Pattern Language for Production LLM Platforms [2] names the **BOE Declaration**: a statement of the **B**oundary a control fixes, the **O**ptimizer it frees, and the **E**vidence proving the boundary held. **Every step in this framework MUST state its evidence artifact as an instance of that declaration.**

Step	Boundary fixed	Optimizer freed	Evidence
S1	A system nobody owns and nothing has tiered may not be developed further	Free choice of what the institution builds, within a known population	The inventory entry, naming owner, tier and rubric version
S2	A system whose assumptions and limits are unstated may not be validated	Free choice of method, features and data within the classified set	The pre-validation record, citing lineage and classification
S3	A system whose behaviour has not been independently examined may not be presented for approval	Free choice of how the system achieves its result within the validated envelope	The validation report, signed by a second-line reviewer
S4	A use nobody is answerable for may not be permitted	Discretion over which uses the institution permits at all	The approval record, naming a person and the five bounds
S5	A system that cannot be tested against its approval conditions may not keep operating	Autonomy inside the conditions the permission set	Monitoring output for the period, with gaps named
S6	A permission may not outlive the conditions it was granted under	Freedom to keep operating a model no trigger has fired on	The revalidation record and the trigger register

5.2 Why the mapping matters

This is not a presentational device. It is what makes a validation record **joinable** rather than merely filed. An incident reconstruction consumes gate records, validation records, residency attestations and vendor screening records together [3, 5.3], and can do so only if all of them state the same three things in the same shape. Two controls that emit evidence in one shape compose. Two that do not are adjacent, however well each is drawn [2].

doi.org/10.5281/zenodo.22285045

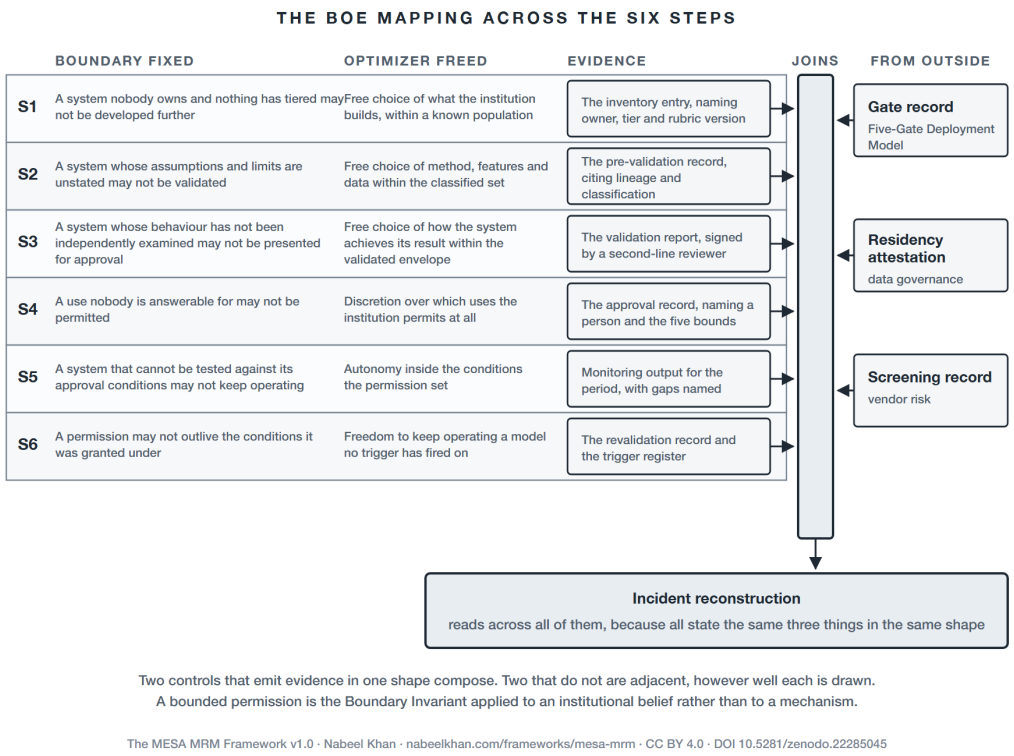


Figure 3. The BOE mapping across the six steps. Each step fixes one boundary, frees one optimizer, and writes the evidence that the boundary held. Because all six records state the same three things in the same shape, they join with the gate records of the Five-Gate Deployment Model, the residency attestations of data governance and the screening records of vendor risk. An incident reconstruction can read across all of them. DOI https://doi.org/10.6084/m9.figshare.33420163

5.3 The invariant this framework instantiates

The Boundary Invariant [2] holds that a boundary is a clause the optimizer may not cross, and everything else is optimization. A bounded permission is that invariant applied to an institutional belief rather than to a mechanism. The permitted use is the clause, everything the builders may change inside it is the optimization, and the approval, monitoring and revalidation records are the evidence that the clause held for as long as it was claimed to hold.

---

6. Composition, and One Edge This Specification Does Not Settle (Normative)

6.1 What this framework consumes

Five frameworks supply inputs, and each is asserted once, in the register of the Defensible AI Framework Registry [3, 5.2], which is the canonical statement of every relationship named here.

- **AI Data Governance** supplies classification and lineage at S2 [3, row 13].
- **AI Vendor Risk (AVRF)** supplies vendor evidence at S2 and S3 where the model is third-party [3, row 17]. The instrument that collects it is published separately [6].
- **AI Incident Response (AIRP)** supplies revalidation triggers into S6 [3, row 20].
- **CADRE™**, the AI governance operating model, grants the approval authority exercised at S4 [3, row 10].
- **SACF** threads the dual-validation branch into S3 [3, row 28], by reference per Section 4.

6.2 What this framework supplies

- **To the Five-Gate Deployment Model**, validation and approval records, as entry criteria at its second and third gates [3, row 11].
- **To the AI Incident Response Protocol**, validation and approval records for reconstruction [3, row 12].

doi.org/10.5281/zenodo.22285045

- **To the MESA Framework**, this framework's position in the Operational Machinery altitude of the maturity vector [3, row 1].

6.3 One edge this specification records and does not settle

The Five-Gate Deployment Model names an artifact of this framework as an entry criterion at a gate the relationship register does not carry.

Five-Gate lists *the revalidation trigger register populated* as an entry criterion at its fifth gate, attributed to MESA MRM [4, 3.6]. The registry's relationship register carries one supply edge from this framework to Five-Gate, at the second and third gates only [3, 5.2 row 11]. The two published records therefore describe a different set of dependencies between the same pair of frameworks.

This specification records the disagreement and does not resolve it. The registry governs placement [3, 11.3], and a deposit that resolved the question in its own favour would be a deposit authoring an edge, which the closure rule forbids [3, 5.4]. Resolution belongs to the next version of the registry.

Three things can be stated without resolving it, and are.

1. **The artifact exists and is required.** S6 requires the trigger register to be populated before the model serves production traffic, independently of any gate. Nothing about the edge question changes that obligation.
2. **An institution citing the fifth-gate criterion today SHOULD cite Five-Gate [4, 3.6] as the source of the criterion and this specification's S6 as the source of the artifact**, rather than citing the relationship register, which does not carry it.
3. **This specification asserts no supply edge at the fifth gate**, and its conformance requirements at Section 7 do not depend on one.

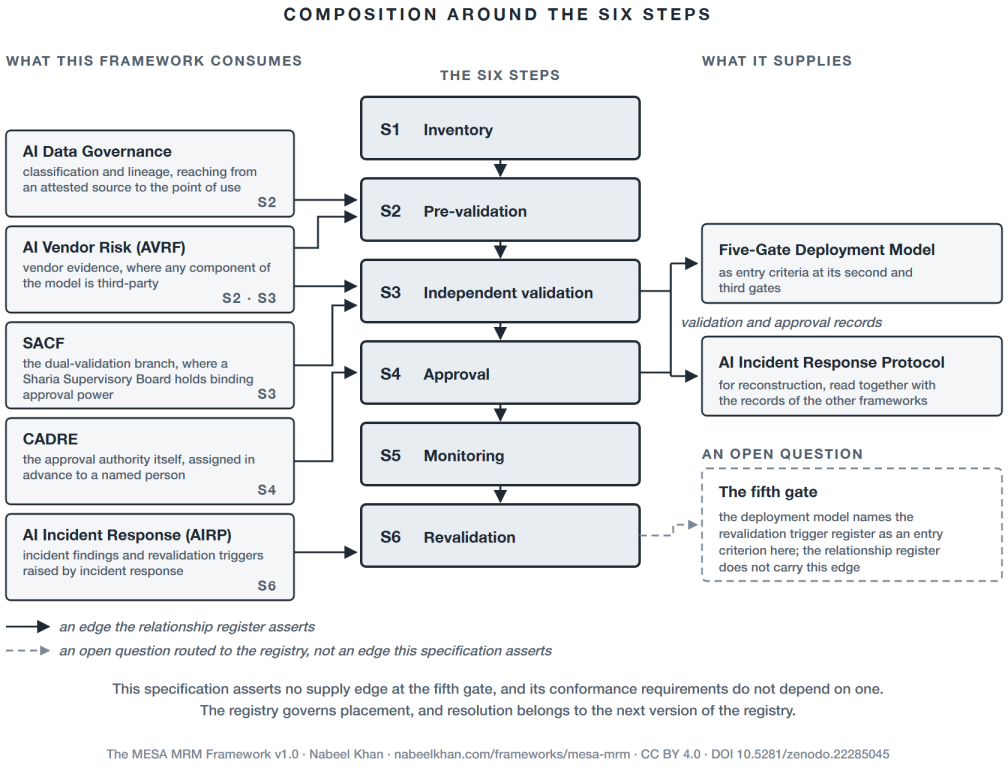


Figure 4. Composition around the six steps. Solid arrows are the register's edges that carry a record: classification and lineage entering at S2, vendor evidence at S2 and S3, the dual-validation thread at S3, approval authority at S4, revalidation triggers at S6, and validation and approval records leaving to the second and third gates of the deployment model and to incident reconstruction. The third outbound edge at 6.2 is not drawn, because it conveys this framework's position in the maturity vector rather than an artifact, and an arrow carrying nothing would read as an evidence flow that does not exist. The single dashed arrow is the edge the deployment model names at its fifth gate and the register does not carry, drawn as an open question routed to the registry rather than as an assertion of this specification. DOI https://doi.org/10.6084/m9.figshare.33420166

doi.org/10.5281/zenodo.22285045

7. Conformance (Normative)

7.1 Self-declared, and nothing else

Conformance is **self-declared**. No conformity assessment body operates against this specification, no third party is accredited to assess a claim made under it, and no certification exists.

7.2 What a conformance claim requires

An institution conforms, **for a stated set of models**, when all of the following hold and are evidenced for every model in that set.

1. The model is registered at S1 with a named owner and a tier assigned by a documented rubric applied before its performance was known.
2. Steps S1 through S6 were completed in order, and no step began before its predecessor completed or was recorded as completed with conditions per 2.4.
3. Every step record exists and carries every field required by 2.5.
4. The head of model risk and the approving executive are two different named individuals for this model, per 2.2.
5. The validator at S3 satisfies the independence requirements at 3.4 and is not the approver at S4.
6. The approval record states all five bounds required by 2.1.
7. Monitoring covering every condition the approval named was live before the model served production traffic, and its output for the period exists with gaps named.
8. The revalidation trigger register was populated before the model served production traffic and records, per trigger, whether it returns the model to S3 or to S4.
9. Every step record states its BOE Declaration, per 5.1.
10. Where a Sharia Supervisory Board holds binding approval power, both validation tracks closed before S4 began, per Section 4.

7.3 What MUST accompany a claim

A published claim MUST state: the set of models claimed, the models deliberately excluded and why, the date of the evidence relied on, and the version of this specification claimed against.

A claim MUST NOT be made for an institution as a whole. Conformance is a property of a model's governance, and an institution-wide claim conceals the models that were never registered.

7.4 What a conformance claim does not mean

- It does not mean the institution is compliant with any statute or supervisory expectation. **Annex A is a cross-walk and is not a compliance claim.**
- It does not mean the models are fit. The steps record who examined what and who permitted what. Fitness is the validator's finding, not the framework's.
- It does not mean the institution has been assessed. Nobody assessed it. It declared.
- It does not mean a certification exists. None does.

7.5 Lapse

An institution ceases to be conformant for a model from the date its monitoring stopped, its permission expired without revalidation, or a step condition passed its date unmet, **not from the date the lapse was discovered**. A conformance claim carries the date of the evidence, and evidence has a currency.

---

8. Related Work

8.1 Supervisory model risk guidance

Two instruments bear most directly on this framework, and **this framework does not duplicate either**. In Canada, OSFI Guideline E-23, Model Risk Management (2027) [8], published 11 September 2025 and effective 1 May 2027, applies model risk expectations to models including those using AI and machine learning methods, and to

doi.org/10.5281/zenodo.22285045

models and data obtained from external sources, tied to Guideline B-10 on third-party risk. In the United States, SR 26-2 [9], issued 17 April 2026 by the Federal Reserve, the Office of the Comptroller of the Currency and the Federal Deposit Insurance Corporation, supersedes and replaces SR 11-7 (2011) and SR 21-8 (2021).

The relationship runs one way. An institution subject to either instrument may find that the six steps give its discipline a lifecycle position, an accountable person and a bounded permission, and **MUST perform its own crosswalk against the primary source in force where it operates**. Annex A exists to make that work cheaper and is informative for the reasons stated there.

8.2 Management system standards

ISO/IEC 42001 [10] specifies a management system for artificial intelligence and the NIST AI Risk Management Framework [11] specifies a risk management structure. Both operate at institutional altitude. Neither specifies a model lifecycle with two separated accountable loci and a bounded permission as its output, which is this framework's subject.

8.3 The governance family

This framework is entry REG-02 of the Defensible AI Framework Registry [3], which is the canonical source for its relationships to the frameworks named throughout Sections 3 and 6. **Where this specification and the registry describe the same relationship, the registry governs.** Where they describe what the framework itself requires, this specification governs [3, 11.3].

The Five-Gate Deployment Model [4] is the closest sibling and the most easily confused with this one. The difference is stated plainly: **Five-Gate governs passage and this framework governs belief.** A gate decides whether a system may move. A validation decides what the institution is entitled to think about it. The second and third gates consume this framework's outputs, and neither replaces the other.

8.4 The source treatment

The framework was named and used before this specification, principally in chapter 12 of [7], which remains a valid citation for the earlier treatment. **Its structures are not this specification's structures**, and Appendix D records the correspondence so that a reader holding the book does not assume an equivalence that does not exist.

---

9. Limitations and What Has Not Been Tested

9.1 No institution unconnected to the author has been observed operating the six steps

The framework is named and used, and no third party has published a result obtained under it. Everything in Sections 2 through 7 is an architectural claim. It is coherent. Whether separating the two loci changes an approval rate is a fact about institutions, and no institution has supplied it.

9.2 The central claim is untested and the comparison is not obvious

The framework asserts that separating the two accountable loci changes the outcome relative to a discipline in which one person holds both. **That has not been measured**, and the alternative is not a straw man. A single strong head of model risk with unquestioned authority to refuse may refuse more often than a separated pair in which each assumes the other is holding the line. 9.8 states what would settle it.

9.3 It is calibrated to institutions that can staff it

Two named roles, two named deputies and an independent validator is at least five appointments, three of which must sit outside the team that builds the model. **An institution too small to make them will operate a compressed form**, and this specification does not say which compressions preserve its properties. The one that certainly destroys them is holding the two loci in one person, which 2.2 forbids.

9.4 The regulatory crosswalk is informative, and it dates

Annex A crosswalks the six steps to two supervisory instruments as verified on 1 September 2026. **A crosswalk is a reading of two documents at a moment, and both documents change.** One of the two instruments

doi.org/10.5281/zenodo.22285045

crosswalked is not yet in force. Annex A states its own verification date and states the institution's obligation to re-verify, and the crosswalk creates no obligation on either supervisor and no presumption in the institution's favour.

9.5 Retirement is named and not specified

S6 refers a model for retirement and closes its inventory entry. The retirement decision is specified elsewhere [4, 4.3], and one of the instruments at Annex A treats decommissioning as a lifecycle component in its own right. **This framework does not specify what a defensible retirement requires.**

9.6 The tiering rubric is required and is not supplied

S1 requires a documented tiering rubric and this specification does not publish one. The rubric determines the depth of every step after it, which makes it the highest-leverage unpublished artifact in the framework. A prior scoring instrument exists in the source treatment and is recorded at Appendix D as prior treatment; **it is not adopted here**, and an institution using it is using the book rather than this specification.

9.7 The name has not been cleared

No trademark clearance search for this name is recorded in the author's published corpus, and this specification does not assert that the mark is available.

9.8 What would falsify the framework

The framework is falsified if institutions operating the six steps with genuine second-line independence, and with the two accountable loci separated, are found to approve unfit models at the same rate, and with the same severity of consequence, as institutions in which the building team validates its own work or in which one person holds both loci.

The framework's entire claim rests on independence changing the outcome. Evidence that it does not would leave a process with no defensible reason to exist, and the correct response would be to replace it rather than to tighten it.

Three narrower findings would falsify parts of it. If permissions carrying no expiry are revisited as promptly as those that carry one, the bounding requirement at 2.1 is paperwork. If institutions recording the unexamined set at S3 approve no differently from those that do not, Annex B's most distinctive section is a heading with nothing under it. And if validation records do not in practice join with gate records and residency attestations during a reconstruction, the BOE mapping at Section 5 describes a join that does not occur.

9.9 Research questions

1. Does separating the two accountable loci change the rate at which unfit models are approved, relative to a single-locus discipline of equal technical strength?
2. What does producing the six step records cost, and at what tier does the cost stop being proportionate to the risk?
3. Do models whose permissions carry a stated expiry get revisited earlier than models whose permissions do not?
4. Does recording the unexamined set change what approvers refuse?
5. Which compressions of the framework preserve its properties in an institution too small to staff it fully?

A reader able to answer any of these from real deployment evidence is invited to make contact through the ORCID record in the front matter.

---

10. Versioning

The major number changes when a change could make a previously conformant claim non-conformant: a step is added, removed or reordered, an entry condition is added, an accountable locus is redefined, or a requirement in Section 7 is tightened.

doi.org/10.5281/zenodo.22285045

The minor number changes for additions and clarifications that cannot, including a new supplier named for an existing condition, a corrected limitation, a re-verified Annex A, or the addition of a tiering rubric.

The step identifiers S1 to S6 and their ordinals are normative and MUST NOT be renumbered, per 2.3. A step retired in a future version retains its identifier, which is marked retired rather than reused.

Annex A carries its own verification date and MAY be re-verified without a change to the rest of this document. A re-verification is a minor version change and MUST update the date, because an annex reporting a stale check as a current one is worse than no annex.

---

11. References

Every external reference was verified against a live primary source on 1 September 2026, each with a deliberate failing control, because a check that cannot fail proves nothing. The verification record is at Annex A.9.

[1] Khan, N. A. (2026). *The MESA Framework: A Four-Altitude Diagnostic Model for Institutional AI Governance. Framework Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22109836

[2] Khan, N. A. (2026). *A Pattern Language for Production LLM Platforms: Governed Routing, Agent Orchestration, and AI-Native Delivery. Pattern Language Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22109864

[3] Khan, N. A. (2026). *The Defensible AI Framework Registry: Canonical Names, Definitions and Relationships for the Governed Production AI Discipline. Registry Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22170112

[4] Khan, N. A. (2026). *The Five-Gate Deployment Model: A Deployment Discipline for AI Systems. Deployment Model Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22170122

[5] Khan, N. A. (2026). *The Sharia AI Compliance Framework: A Dual-Authority Governance Architecture for Islamic Finance. Framework Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22170143

[6] Khan, N. A. (2026). *The AI Vendor Due-Diligence Questionnaire: AVRF Instrument for Third-Party AI Systems, Models and APIs. Questionnaire Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22170146

[7] Khan, N. A. (2026). *AI Governance and Compliance Frameworks for the Middle East: The Enterprise Playbook.* First Edition. iSystematic Inc. ISBN 978-1-0678960-1-0

[8] Office of the Superintendent of Financial Institutions, Canada (2025). *Guideline E-23, Model Risk Management (2027).* Published 11 September 2025, effective 1 May 2027. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027

[9] Board of Governors of the Federal Reserve System, Office of the Comptroller of the Currency and Federal Deposit Insurance Corporation (2026). *SR 26-2, Revised Guidance on Model Risk Management.* Issued 17 April 2026. Supersedes and replaces SR 11-7 (4 April 2011) and SR 21-8 (9 April 2021). https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm . Guidance attachment: https://www.federalreserve.gov/supervisionreg/srletters/SR2602.pdf . *Footnote 3 of the attachment places generative AI and agentic AI models outside its scope; it MUST NOT be cited as an AI-specific instrument.*

[10] International Organization for Standardization and International Electrotechnical Commission (2023). *ISO/IEC 42001:2023, Information technology. Artificial intelligence. Management system.* First edition, December 2023.

[11] National Institute of Standards and Technology (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0).* NIST AI 100-1, 26 January 2023.

---

doi.org/10.5281/zenodo.22285045

Annex A (Informative). The Regulatory Crosswalk

A.1 What this annex is, and what it is not

This annex is informative in its entirety. Nothing in it is normative, nothing in it creates a conformance requirement, and nothing in it establishes compliance with any instrument.

The registry entry for this framework records, as its first limitation, that the source treatment contains no written crosswalk to current Canadian or United States supervisory guidance, and that an institution relying on the framework for supervisory alignment must perform that crosswalk against the primary sources in force in its jurisdiction [3, 4.2.13]. **That posture is unchanged by this annex.** The crosswalk is the institution's obligation to perform and to maintain. It is not this framework's obligation to guarantee.

What this annex does is narrower and is worth stating exactly. It records how the six steps were read against two named instruments on one named date, so that an institution performing its own crosswalk starts from a reading it can check rather than from a blank page. Three properties follow.

1. **A crosswalk dates.** Both instruments may be amended, withdrawn, supplemented by supervisory expectations expressed outside them, or interpreted by a supervisor in a way this reading did not anticipate. **One of the two is not yet in force.**
2. **A crosswalk is jurisdictional.** The two instruments here cover Canada and the United States. An institution operating elsewhere is not served by this annex at all.
3. **A crosswalk is not a mapping of obligations.** Where a row below says a step corresponds to a section, it means the two address the same subject. It does not mean that performing the step discharges the section.

The date of verification is 1 September 2026. An institution relying on any row below MUST re-verify against the primary sources in force where it operates, and MUST date its own reading.

A.2 The two instruments as verified

	OSFI Guideline E-23	**SR 26-2**
Full name	Guideline E-23, Model Risk Management (2027)	Revised Guidance on Model Risk Management
Issuer	Office of the Superintendent of Financial Institutions, Canada	Board of Governors of the Federal Reserve System, the Office of the Comptroller of the Currency, and the Federal Deposit Insurance Corporation, jointly
Published or issued	11 September 2025	17 April 2026
Effective	**1 May 2027**, after a transition period	On issue
Replaces	The earlier E-23	**SR 11-7 (4 April 2011) and SR 21-8 (9 April 2021)**, superseded and replaced
Applies to	Federally regulated financial institutions, including foreign bank branches and foreign insurance company branches, on a risk basis proportional to size, strategy, risk profile, nature, scope and complexity of operations	Stated as most relevant to banking organizations with over thirty billion dollars in total assets regulated by the Federal Reserve
Definition of a model	An application of theoretical, empirical or judgemental assumptions or statistical techniques, including AI and machine learning methods, processing input data to generate results	A complex quantitative method, system or approach applying statistical, economic or financial theories to process input data into quantitative estimates, excluding simple arithmetic and deterministic rule-based processes
Treatment of AI	AI and machine learning methods are inside the definition of a model; explainability is a consideration at design and at review	**Footnote 3 places generative AI and agentic AI models outside the scope of the guidance**, while stating that its principles apply to traditional statistical and quantitative models and to non-generative, non-agentic AI models

doi.org/10.5281/zenodo.22285045

	OSFI Guideline E-23	SR 26-2
Third-party models	Covered, with external sources handled in conjunction with Guideline B-10 on third-party risk management	Covered, in a dedicated section on vendor and other third-party products
Structure used below	A Overview, B Enterprise-wide model risk management, C Risk-based approach (model identification, model risk rating, risk management intensity), D Model lifecycle management (design, review, approval, deployment, monitoring, decommission), Appendix 1	I Introduction, II Purpose and Scope, III Overview of Model Risk and Model Risk Management, IV Model Development and Model Use, V Model Validation and Monitoring, VI Governance and Controls, VII Vendor and Other Third-Party Products

The date-of-effect line is the one most often misreported and was checked twice. Guideline E-23 takes effect **1 May 2027**, not 1 April 2027. A control question asserting 1 April was put to the primary source and was refused; the record is at A.9.

A.3 The six steps against Guideline E-23

Step	Nearest treatment in E-23	What the instrument reaches that the step does not	What the step fixes that the instrument leaves open
S1 Inventory	Model identification and the model inventory; model risk rating	Requires the inventory to be enterprise-wide, accurate, evergreen and controlled, which is a stronger statement about the inventory as a system of record than S1 makes	S1 requires the tiering rubric to be applied before the model's performance is known, and requires one named person as owner
S2 Pre-validation	The design components of the lifecycle: rationale, data and development	Treats model rationale as a distinct component, including whether the model is the right instrument at all	S2 requires the builder's assumptions and limits to be written before validation, and makes an undisclosed limit a finding against pre-validation
S3 Independent validation	Model review, which is to be independent of development and proportionate in extent and frequency to the model risk rating	Frames review as recurring by rating rather than as a single event	S3 requires the unexamined set to be recorded, and forbids the validator from being the approver
S4 Approval	Model approval, as a distinct lifecycle component	Names approval as its own stage, which SR 26-2 does not	**E-23 permits the approval authority to be a unit, an individual or a committee. S4 does not.** See A.5
S5 Monitoring	Model monitoring, to keep models fit for purpose and detect performance issues or breaches	Ties monitoring to the fit-for-purpose determination directly	S5 names the override rate as a required signal and requires monitoring gaps to be named rather than interpolated
S6 Revalidation	Review triggered by scheduled risk-based periodic review and by other events, at a frequency commensurate with the rating	Places periodic review inside the review component rather than as a separate step	S6 requires the trigger register to record, per trigger, whether the model returns to validation or only to re-approval

doi.org/10.5281/zenodo.22285045

Step	Nearest treatment in E-23	What the instrument reaches that the step does not	What the step fixes that the instrument leaves open
(none)	**Model decommission**	**E-23 treats decommissioning as a lifecycle component. This framework does not specify it**, and 9.5 records the gap	

A.4 The six steps against SR 26-2

Step	Nearest treatment in SR 26-2	Note
S1 Inventory	Model inventory, within Governance and Controls	Described as common industry practice rather than as a requirement, with the level of information varying by complexity and usage
S2 Pre-validation	Model Development and Model Use	Covers development, testing, documentation and the consideration required when a model's use is extended beyond its original application, which is the closest the guidance comes to the bounding idea at 2.1
S3 Independent validation	Model Validation and Monitoring, and the effective challenge principle in the overview	**The guidance frames the control as effective challenge by objective experts with sufficient independence, expertise, standing and influence, rather than as a named second line.** This is a materially different construction from S3, and it is the one most likely to mislead a reader who assumes the two are the same thing
S4 Approval	**No approval stage.** Approval is referred to once and incidentally, in the context of ongoing monitoring before and after a model is approved for use	The guidance names no approving person and makes no requirement about who approves. **S4 is stricter than the instrument on this point and the institution should not expect the instrument to supply the requirement**
S5 Monitoring	Ongoing monitoring, within Model Validation and Monitoring, including outcomes analysis and backtesting	Frequency and scope depend on the nature of the model, data availability and materiality
S6 Revalidation	Handled inside validation and monitoring rather than as a distinct step; adjustment, recalibration or redevelopment where performance thresholds are breached	No trigger register construct appears
Tiering	**Materiality, not tiering.** In the text extracted from the attachment on 1 September 2026, the word tier does not appear; intensity is scaled by model exposure, purpose and use	An institution translating an S1 tier into an SR 26-2 conversation should expect to be asked about materiality and to have to show the mapping
Third-party models	Vendor and Other Third-Party Products	States that the principles of model risk management remain applicable where the institution does not receive the underlying code, data or methodology, which is the position the AVRF instrument [6] was built to make actionable

A.5 Four places where this framework is stricter than both instruments

Recorded because a reader who assumes the framework is a restatement of supervisory expectation will be wrong in these four places, and because being stricter than an instrument is not a claim to satisfy it.

doi.org/10.5281/zenodo.22285045

1. **The approving executive must be one person.** E-23 expressly contemplates a committee as an approval authority. SR 26-2 names no approver at all. **This framework forbids a committee** at 2.2, on the reasoning stated there and at [3, 3.3]. An institution operating the framework inside an E-23 population is choosing the narrower option the guideline allows rather than complying with a requirement the guideline makes.
2. **The two loci must be separated.** Neither instrument requires that the person accountable for the model risk discipline be a different person from the one who approves individual models.
3. **The permission must be bounded, with an expiry or a trigger.** Neither instrument requires an approval to carry an expiry. E-23 requires review frequency commensurate with the rating, which is adjacent and is not the same requirement.
4. **The unexamined set must be recorded.** Neither instrument requires a validation to state what it did not examine.

A.6 Three places where an instrument reaches further than this framework

1. **Decommissioning.** E-23 treats it as a lifecycle component. This framework refers a model for retirement and does not specify the retirement. See 9.5.
2. **Model rationale.** E-23 asks whether a model is the right instrument at all, before it asks whether the model is sound. S2 assumes the question has been settled elsewhere.
3. **Aggregate and interconnected model risk.** SR 26-2 addresses interactions and dependencies among models, common assumptions and shared data, and the possibility of several models degrading together. **This framework governs one model at a time**, and an institution operating it will not thereby see a correlated failure across a model estate.

A.7 The scope divergence that matters most

The two instruments do not agree about whether the systems most institutions now call AI are models at all.

Guideline E-23 includes AI and machine learning methods inside its definition of a model and treats explainability as a consideration at design and at review.

SR 26-2 does the opposite for one class of system. Footnote 3 of the attachment states that generative AI and agentic AI models are novel and rapidly evolving and, as such, are not within the scope of the guidance, while stating that the guidance's principles apply to traditional statistical and quantitative models and to non-generative, non-agentic AI models. The footnote also states that a banking organization's own risk management and governance practices should guide the determination of appropriate governance and controls for tools, processes or systems not covered.

Three consequences follow for an institution operating the six steps, and all three are the institution's to act on.

1. **A generative or agentic system in a United States banking organization is governed by the institution's own arrangements**, not by SR 26-2. This framework is one such arrangement, and its being one does not make it supervisory expectation.
2. **The same system in a Canadian federally regulated institution is inside E-23's definition of a model**, so the same estate can be in scope on one side of the border and out of scope on the other.
3. **SR 26-2 MUST NOT be cited as an AI-specific instrument.** It is the current United States model risk guidance and it is expressly not that.

A.8 What the institution must do

This annex is a starting point and is not a substitute for any of the following.

1. **Identify the instruments actually in force where the institution operates**, which will frequently include instruments neither named here.
2. **Re-verify the facts at A.2 against the primary sources**, and date the reading. The date of the reading is part of the finding.
3. **Perform the crosswalk against its own control set**, not against this framework's steps, because it is the institution's controls that a supervisor will examine.
4. **Record where the institution is stricter than the instrument and where the instrument reaches further**, in both directions, because a crosswalk that shows only alignment is a crosswalk that was written to reassure.
5. **Re-perform it when either document changes.** E-23 comes into force on 1 May 2027, and a crosswalk performed before that date against a guideline not yet in force is a preparation rather than a compliance record.

doi.org/10.5281/zenodo.22285045

A.9 Verification record

Every fact in A.2 through A.7 was checked against a live primary source on **1 September 2026**, and each check was paired with a deliberate failing control, because a check that cannot fail proves nothing.

#	Claim checked	Source	Control put to the same source	Control result
1	E-23 published 11 September 2025, effective 1 May 2027, third-party models in scope	OSFI guideline page for Guideline E-23 (2027)	Asserted an effective date of 1 April 2027, a 2024 publication, and exclusion of third-party models	**Refused all three**, quoting the effective date, the publication date and the third-party provisions against them
2	SR 26-2 issued 17 April 2026, supersedes SR 11-7 and SR 21-8, most relevant above thirty billion dollars in assets	Federal Reserve supervisory letter page for SR 26-2	Asserted an issue date of 17 March 2025, supersession of SR 15-18, and a five billion dollar threshold	**Refused all three**, quoting the issue date, the two superseded letters and the threshold against them
3	SR 26-2 footnote 3 excludes generative and agentic AI models	The guidance attachment, retrieved and read directly rather than through a summary	The first retrieval returned an unreadable encoding and **declined to answer rather than inventing quotations**, which is itself the control the summary route would not have provided	Text then extracted from the retrieved document and read in place
4	The corpus already records the same two instruments consistently	The author's own deposited records	A control search for an absent term returned zero.	**Zero matches**, confirming the search would have reported an absence if there were one

One limit of this record. The section structure and the quoted definitions of Guideline E-23 at A.2 were read from the guideline's published page. The SR 26-2 facts were read from the letter and from the guidance attachment directly. Where a claim at A.4 rests on the absence of a term in the attachment, the method is named in the row that makes it, because an absence found by text extraction is weaker evidence than a presence found the same way.

Annex B (Normative). The Validation Report Template

A validation report conforming to this specification carries the following sections in this order. **A section with nothing to record carries an explicit statement that there is nothing to record**, because an absent section and an empty section are different claims.

#	Section	What it MUST contain
1	**Identification**	The system, its version, its inventory identifier, its tier and the rubric version that assigned it, the report identifier, and the date
2	**Validator and independence**	The named validator, the function they sit in, and a positive statement against each of the three independence requirements at 3.4
3	**Scope, as set in advance**	The scope recorded before the work began, and any change to it during the work with the reason
4	**The claims under test**	The assumptions and limits as stated by the builder at S2, reproduced by reference so that the report tests a fixed statement
5	**Data examined**	The data sets, their classification, the lineage relied on, and the period covered
6	**Method**	What was done, in enough detail that a second validator could repeat it
7	**Findings**	Each finding with a severity, an owner and a date
8	**Performance on the validated population**	Stated against the population, not in the abstract

doi.org/10.5281/zenodo.22285045

#	Section	What it MUST contain
9	**Populations examined and populations not examined**	Named individually
10	**The unexamined set**	**The limitations, failure modes, populations, inputs and use cases this validation did not examine.** Required. An approval granted on this report is blind in the shape of this section
11	**Vendor evidence relied on**	Where any component is third-party: what was supplied, what was refused, and what the validator could not examine. Collected per [6]
12	**Dual-validation status**	Where SACF applies: the identifier and date of each of the two closures, per Section 4. Otherwise a statement that the branch does not apply
13	**Recommended bounds**	The use, population, period and conditions the validator recommends the permission be bounded by, in the form S4 requires at 2.1
14	**Decision**	Closed, closed with conditions, or not closed, with each condition owned and dated
15	**BOE Declaration**	The boundary this validation fixes, the optimizer it frees, and the evidence, per 5.1
16	**Signature**	The validator's name and the date. **A report no second-line reviewer signed is not evidence of independent validation**

Section 10 is the section that distinguishes this template. Reports commonly state what was found. A report that does not also state what was never looked at hands the approver a boundary they cannot see. The approver then grants a permission wider than the evidence supports, without any party having made a decision to do so.

Annex C (Informative). A Worked Example

This example is constructed. It is not a record of an institution, and nothing in it is evidence of anything. It exists to show the shape of a conforming report and to show one refusal, because a template illustrated only by a clean pass teaches the wrong lesson. No institution is named, no figures are real, and the example tests no claim this specification makes.

The system. A retail credit scoring model, third-party in origin with locally fitted calibration, proposed for use in a single product line and a single jurisdiction.

S1. Registered before development proceeded beyond a prototype. One named owner, in the lending business. Tier assigned high by the institution's documented rubric on regulatory impact and per-decision consequence, and assigned before any performance figure existed. Rubric version and date recorded on the entry.

S2. The owner records the assumption register: that applicant behaviour in the coming period resembles the fitting period; that the two acquisition channels behave alike; that the vendor's underlying feature construction is stable across releases. The stated limits: not fitted for thin-file applicants, and not fitted for a second product line. Lineage from an attested source to the point of use, classification carried from data governance, vendor evidence collected per the AVRF instrument. Pre-validation completes with one condition: the vendor has not supplied the fitting population's composition, owned by the vendor manager, dated.

S3. Validator drawn from the second line, not in the lending reporting chain, and not the person who will approve. Scope set in advance to the tier. The validator tests the three assumptions, reproduces the calibration, and tests performance on holdout data the building team did not see.

Two findings. First, the two acquisition channels do not behave alike; the model is materially weaker on one of them. Second, the thin-file applicants, whom the builder correctly excluded, are a growing share of the applicant flow, so the stated limit will bind harder over time than the builder assumed.

Section 10, the unexamined set, records four things: no examination of the second product line, since it was not proposed; no examination of behaviour under an economic downturn, since no downturn appears in the available data; no examination of the vendor's feature construction, which was not disclosed; and no examination of applicants under a specific age threshold, whose volume was too low to test.

doi.org/10.5281/zenodo.22285045

Decision: closed with conditions. The validator recommends bounds narrower than proposed: one product line, one jurisdiction, one acquisition channel, twelve months, with a trigger on the share of applicants lacking domestic credit history crossing a stated threshold.

S4. The approving executive, who is not the validator and is not the head of model risk, reads the report and refuses the second acquisition channel outright rather than accepting it with a compensating control, on the ground that the compensating control proposed would have been operated by the channel it was meant to constrain. **The departure from the validator's recommendation is recorded, with the reason.** The approval names the person, the evidence and the five bounds, the fifth of which is the two open conditions, each owned and dated.

S5. Monitoring is live before the first production decision. It covers each named condition, input and output drift, the served population against the validated population, and the override rate. In the fourth month the override rate rises in one branch network. This is not a threshold breach, so it is recorded as a finding within conditions rather than as an incident, and it is carried into the next revalidation.

S6. The trigger register, populated before production, records the applicant-composition trigger as returning the model to **S3**, and the twelve-month expiry as returning it to **S4**. In the ninth month the composition trigger fires. The model returns to S3, not to S4, because the register said so before anyone had an interest in the answer.

What the example is meant to show. Not that the process caught something. It is constructed, so it caught nothing. What it shows is which artifact carried each decision, that the refusal at S4 is recorded rather than smoothed away, and that the choice between returning to S3 and returning to S4 was made in advance by a register rather than in the moment by the people whose work would be reopened.

Appendix D (Informative). Naming Crosswalk to the Source Treatment

The framework was treated at chapter length before this specification [7, chapter 12]. **That treatment used different structures under the same name**, and a reader holding the book needs to know which terms carry forward, which are prior names, and which are not adopted. This appendix records that and nothing else.

The registry governs the framework's structure [3, 4.2], and this specification governs the framework's requirements [3, 11.3]. Neither is governed by the source treatment.

D.1 Structures that are prior treatment and are not this specification's structure

Prior structure	What it was	Status
The six pillars: Model Governance, Model Development, Independent Validation, Deployment and Implementation, Ongoing Monitoring and Revalidation, Sharia Compliance Integration	Six concurrent disciplines, expressly not sequential	**Prior treatment. Valid for citation of the earlier work. Not the six steps.** The pillars and the steps are both six and are not the same six
The six-stage lifecycle: Development, Validation, Deployment, Ongoing Monitoring, Revalidation, Retirement	A sequential lifecycle with a checkpoint at each stage	**Prior treatment.** It has no inventory stage and it has a retirement stage; the six steps have an inventory step and refer retirement out to [4, 4.3]
The Model Risk Classification Matrix	A ten-dimension scored instrument producing High, Medium and Low risk	**Prior treatment, not adopted.** S1 requires a documented tiering rubric and does not publish one. See 9.6
The MESA Model Card	A twelve-section artifact declaring the model	**Prior treatment.** Not required by this specification. An institution using it is using the book
The thirteen-section validation report	The earlier report structure	**Superseded for conformance purposes by Annex B**, which is sixteen sections and adds the unexamined set, the independence statement, the recommended bounds and the BOE Declaration

doi.org/10.5281/zenodo.22285045

Prior structure	What it was	Status
Pass, Conditional Pass, Fail	The earlier validation decision vocabulary	**Prior names for closed, closed with conditions, and not closed** at 3.4

D.2 One assignment in the source treatment that this specification and its siblings forbid

The source treatment assigns deployment approval, and retirement approval, to the AI Governance Committee.

A committee cannot hold either. The registry states the rule once for the whole governance family: a committee, a function, a team or a board MUST NOT be recorded as the accountable role [3, 3.3]. The Five-Gate Deployment Model states the same prohibition at every gate and states that a record naming a committee is not a gate passage record [4, 2.3, 3.4]. This specification states it at 2.2 and at 3.5.

This is recorded as a correction, not as an ambiguity. Where the source treatment and this specification differ on who may approve, this specification governs for the framework and the registry governs for the family. An institution that read the chapter and constituted a committee as its approval authority has an arrangement that is not conformant with Section 7, and the remedy is to name a person, in advance, with a deputy.

D.3 Terms that carry forward unchanged

Independent validation performed by a second line; the principle that validation is what makes a model's output believable outside the team that built it; the dual-validation requirement where a Sharia Supervisory Board holds binding approval power, now specified at [5] and referenced at Section 4; and the requirement that revalidation be triggered rather than merely scheduled.

Appendix E (Informative). Figure Specifications

No figures are drawn in this document. Each figure is deposited separately with its own identifier, and the caption in the body carries the placeholder until it is minted. The specifications below are what each figure must show. They are instructions to a draughtsman, not descriptions of an existing drawing.

Figure 1. The two accountable loci. Two columns. Left column: the head of model risk, with a vertical span covering all six steps, annotated with the five discipline obligations at 2.2. Right column: the named approving executive, with a span covering S4 only, annotated with the two approval obligations. A single dashed line between the two columns, crossed out, labelled with the one arrangement the framework forbids. Deputies shown as a second name under each role. No committee shape appears anywhere in the figure.

Figure 2. The six steps. A left-to-right sequence, S1 through S6, each box carrying the step name, the accountable locus, and the one artifact it writes. Three return arrows beneath the sequence: S3 to S2, S4 to S3, and S6 to either S3 or S4 with the fork labelled by the question the trigger register answers. A closing arrow from S6 back to S1 labelled with the inventory-entry closure on retirement. The permission produced at S4 drawn as a bounded region spanning S5 and S6, the region itself labelled with the system and its version, and its four visible edges labelled use, population, period and conditions.

Figure 3. The BOE mapping. Six rows, one per step, three columns: boundary fixed, optimizer freed, evidence. A fourth column on the right showing the joining: each evidence artifact connecting into a single reconstruction lane, alongside a gate record, a residency attestation and a vendor screening record entering the same lane from outside the framework.

Figure 4. Composition. The six steps as a spine. Inbound solid arrows: classification and lineage into S2; vendor evidence into S2 and S3; the dual-validation thread into S3; approval authority into S4; revalidation triggers into S6. Outbound solid arrows: validation and approval records to the second and third gates of the deployment model, and to incident reconstruction. One dashed outbound arrow from S6 to the fifth gate, drawn in a different weight and annotated as an open registry question rather than an asserted edge, per 6.3.

---

doi.org/10.5281/zenodo.22285045

Appendix F. Publication Provenance

F.1 What this document is. The first public version of the MESA MRM Framework specification. It has not been peer reviewed. It is deposited on Zenodo, which confers a DOI, a timestamp and citability. **Zenodo does not confer standard status, and nothing in this document uses the word standard for itself.**

F.2 Relationship to prior publication. The framework was named and used before this specification, principally in [7]. This document is its first standalone, versioned statement, and Appendix D records what the earlier treatment called things.

F.3 What this deposit closes. The registry entry records two limitations that this deposit addresses [3, 4.2.13]. The missing validation report template and worked example are supplied at Annex B and Annex C. The asserted supervisory alignment is addressed at Annex A **in the only honest form available**, which is an informative crosswalk carrying its own date and its own statement that the obligation remains the institution's.

F.4 No preprint. This specification carries no preprint identifier, and no relation to any preprint is asserted in its metadata, because none exists.

F.5 Registry status. On publication, the registry entry's specification status moves from `source-treatment` to `deposited` and carries this document's concept DOI, which is a minor version change to the registry under [3, 11.1]. The entry's definition is then reconciled with this specification, with this specification governing [3, 11.2]. **Two reconciliations are already known and are recorded here so that they are not discovered later**: the principle at 1.2, stated in the entry as the right to be believed and stated here in its operative form; and the edge question at 6.3, which is the registry's to resolve.

F.6 Verification method. Every external reference in Section 11 was checked against a live primary source with a deliberate failing control, on 1 September 2026. The record is at Annex A.9. **On 15 September 2026, the publication date, all four external references were re-confirmed against live primary sources**, each again with a deliberate failing control: Guideline E-23 and SR 26-2 on their issuers' own pages, the NIST framework from the document served by its DOI, and ISO/IEC 42001 from the IEC webstore, ISO having refused an automated request. **That re-confirmation covers the references, not the crosswalk at Annex A, which keeps the date of its own reading.**

F.7 Funding and conflicts. The work is unfunded. The author operates a consulting practice applying this framework, which is a conflict of interest stated here. The mitigations are the lesser ones available to any single-author instrument: the step identifiers cannot be renumbered, the falsification conditions are published, and the limitations at Section 9 are stated rather than inferred. **None of these makes the specification independent.**

Document History

Version	Date	Summary
1.0	15 September 2026	First public version. Six steps with entry conditions, accountable roles, outcome vocabularies, return paths and evidence artifacts; two accountable loci with a separation requirement; the bounded permission; the BOE mapping; self-declared conformance; the informative regulatory crosswalk at Annex A; the validation report template at Annex B; a worked example at Annex C; the naming crosswalk to the source treatment at Appendix D

About the Author

Nabeel Khan is an enterprise AI architect and governance advisor, and Founder & Solutions Architect at iSystematic Inc. He has spent twenty-five years architecting enterprise data and machine-learning systems in government, healthcare, financial services and telecommunications across three continents, grounded in TOGAF, DMBOK, ISO 27001 and SOC 2.

doi.org/10.5281/zenodo.22285045

He works on governed production AI; systems whose authority is bounded by the architecture, whose decisions carry the evidence needed to defend them, and whose behaviour the institution can explain afterwards. The frameworks specified here, and the regulatory knowledge behind them, are published as machine-accessible AI expertise and are callable over MCP without a key at mcp.nabeelkhan.com/api/mcp, so a reader may query this specification's contents directly and receive answers carrying their source.

ORCID 0009-0005-5364-914X · nabeelkhan.com · Canada

Licence

© 2026 Nabeel Khan. Text licensed under the Creative Commons Attribution 4.0 International licence (CC BY 4.0). The MESA MRM Framework™ and the MESA Framework™ are trademarks of the author and iSystematic Inc.; the licence grants no rights in the marks.

Annex B, the validation report template, is published under the same licence and may be adopted, adapted, translated and built into tooling without further permission.

How to attribute this work

This work is licensed CC BY 4.0. Section 3(a)(1)(A) of that licence requires attribution in the manner the licensor requests, and Section 3(a)(1)(C) requires a link to the material where practicable. This section is that request. Please use one of the following.

Short credit, for slides, diagrams and internal documents:

```
The MESA MRM Framework™ by Nabeel Khan ·
  https://nabeelkhan.com/frameworks/mesa-mrm · CC BY 4.0
```

Inline credit, for web pages, articles and product documentation:

```
Based on <a href="https://nabeelkhan.com/frameworks/mesa-mrm">The
  MESA MRM Framework™</a> by Nabeel Khan,
licensed under <a href="https://creativecommons.org/licenses/by/4.0/">CC
  BY 4.0</a>.
```

Academic citation:

```
Khan, N. A. (2026). The MESA MRM Framework: A Six-Step Model Risk
  Management Discipline for AI Systems.
(Version 1.0). Zenodo. https://doi.org/10.5281/zenodo.22285045
```

The DOI given is the concept DOI and always resolves to the latest version. Cite it unless you need to pin one specific version.

If you have adapted the work, say that changes were made, and do not imply that this author or iSystematic Inc. endorses your version.

Trademarks. The MESA MRM Framework™ is a trademark of the author and iSystematic Inc. The CC BY licence covers the text and figures and grants no rights in the mark. Do not use the mark as, or as part of, the name of your product or service.